CASE STUDY

SmarterTools SmarterMail Exploitation and Ransomware, 2026 (CVE-2026-23760, CVE-2026-24423, CVE-2025-52691): A Case Study

A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.

Executive summary

The people who carried this one were the admins who run SmarterMail on their own servers, and the first many of them heard of it was from researchers and CISA, not the vendor (**Inferred** from [13] [15] [18]). SmarterMail is a mail server its customers host themselves, and in January 2026 three of its flaws went from patch to mass exploitation in days.

Build 9511 fixed a password-reset bypass and an unauthenticated command-execution flaw on 15 January [4] [6] [13] (**Confirmed**); a forum post two days later described a successful attack [15] (**Reported**). With an older file-upload flaw, all three were in CISA's Known Exploited Vulnerabilities (KEV) catalog by 5 February and marked as used in ransomware by April [9] [10] (**Confirmed**).

The vendor was a victim too. SmarterTools says its own unpatched SmarterMail VM let attackers in on 29 January, about 12 Windows servers appeared to be compromised, and SentinelOne stopped the encryption; it blames the "Warlock Group" [14] (**Confirmed** as the vendor's statement). ReliaQuest tied a separate intrusion to the China-based actor Storm-2603 [20] (**Reported**).

Key facts at a glance

Field	Value
Flaws	CVE-2025-52691 file upload (CWE-434, CVSS 10.0); CVE-2026-23760 password-reset bypass (CWE-288, 9.8); CVE-2026-24423 ConnectToHub command execution (CWE-306, 9.8) [2] [4] [5] [6] [7]
Fixed	Build 9413 (9 Oct 2025) per CSA [3] [13]; Build 9511 (15 Jan 2026) per the CVE and NVD records and CODE WHITE [4] [5] [6] [7] [13] [17]
KEV	Added 26 Jan 2026 (CVE-2025-52691, CVE-2026-23760) and 5 Feb 2026 (CVE-2026-24423); ransomware use Known for all three (catalog 2026.11.10) [9]
Named actors	"Warlock Group" (vendor, about its own breach) [14]; Storm-2603 (ReliaQuest, moderate-to-high confidence) [20]
Victims named	SmarterTools itself; no other victim, sector or regulator filing in any source opened [14]

Key findings

- **Attackers moved within two days of the patch.** watchTowr reported the password-reset bypass on 8 January, the fix shipped on 15 January, and a forum post on 17 January described a successful attack, before any CVE was published [15] (**Reported**).
- **The vendor's notes never said "exploited".** The release notes for Builds 9413, 9511 and 9518 read only "IMPORTANT: Critical security fixes." and name no CVE [13] (**Confirmed**). The exploitation record comes from CISA and researchers [9] [15] [18] (**Confirmed** and **Reported**).
- **Patching did not evict attackers.** The vendor says attackers planted files and waited 6 to 7 days, so some customers were compromised even after updating, because the access predated the update [14] (**Confirmed** as the vendor's statement).

Top recommendations

1. Run the current build: hardening continued through Build 9805 on 5 November 2026 [13] (**Confirmed**).
2. Treat any server reachable before it ran a fixed build as compromised until a hunt says otherwise [14] [20] (**Confirmed** as vendor statement; **Reported** as ReliaQuest advice).
3. Hunt for what the vendor lists: Velociraptor, JWRapper, SimpleHelp, random-named .ps1 and .aspx files, unusual local admins, startup items and scheduled tasks [14] (**Confirmed** as vendor guidance).
4. Keep mail servers in a DMZ and allow only mail protocols outbound [20] (**Reported**); F5 says egress filtering would have blocked the attack it saw [21] (**Reported**).
5. Inventory every instance; the vendor's breach began on one forgotten server out of about 30 [14] (**Confirmed** as the vendor's statement).

Scope and method

This brief covers the three SmarterMail CVEs in KEV and the intrusions tied to them, to the KEV catalog of 10 November 2026, at advisory level. No exploit request, payload or command is reproduced, and the public watchTowr repository that NVD tags as an exploit reference is named only because NVD lists it.

Grade	Meaning in this study
Confirmed	Stated in a primary opened for this study: the CVE, NVD and KEV records, the kev-data commit history, the CISA and CSA alerts, the vendor release notes and breach post, a researcher's advisory for its own finding, the Intelligence Hub data and the library's own files
Demonstrated	A researcher showed it technically: a public repository or sensor and telemetry data
Reported	Stated by news or a research firm about someone else, and not confirmed in a primary
Inferred	This study's own reasoning from cited facts, labelled where it appears

All sources were opened on 11 November 2026. KEV ransomware-flag dates come from the commit history of CISA's kev-data repository [10]. No search engine was available, so regulator filings were not checked; "none found" means none in the sources opened. Not opened: watchTowr's blog on CVE-2025-52691, Halcyon's October 2025 Warlock report, Microsoft's Storm-2603 profile and Cisco Talos's Warlock analysis.

Part 1: what happened

Date	Event	Sources	Grade
9 Oct 2025	Build 9413 ships: "IMPORTANT: Critical security fixes." with no CVE named	[13]	Confirmed
29 Dec 2025	CSA alert AL-2025-124 and the CVE record for CVE-2025-52691; NVD publishes the same day	[1] [2] [3]	Confirmed
8 to 13 Jan 2026	watchTowr reports the password-reset bypass; the vendor acknowledges it	[15]	Confirmed
15 Jan 2026	Build 9511 ships; CODE WHITE's disclosure date for both 2026 flaws; CVE-2026-23760 reserved	[4] [13] [17]	Confirmed
17 Jan 2026	A SmarterMail forum post describes a successful attack	[15]	Reported
22 to 23 Jan 2026	Both 2026 CVEs published, CISA's decision record for CVE-2026-23760 grading exploitation active; watchTowr, Huntress and VulnCheck publish	[4] [5] [6] [8] [15] [18]	Confirmed; Huntress Demonstrated and Reported
26 Jan 2026	CISA adds CVE-2025-52691 and CVE-2026-23760 to KEV; Shadowserver starts scanning and sees exploitation attempts	[9] [11] [19]	Confirmed; Shadowserver Demonstrated
29 Jan 2026	The vendor's network is breached through its unpatched SmarterMail VM	[14]	Confirmed (vendor)
3 Feb 2026	Vendor's breach summary, naming the "Warlock Group"	[14]	Confirmed (vendor)
5 to 6 Feb 2026	CISA adds CVE-2026-24423 to KEV; its ransomware flag goes to Known within hours; news reports it	[7] [9] [10] [12] [23]	Confirmed; news Reported
9 Feb 2026	ReliaQuest ties a CVE-2026-23760 intrusion to Storm-2603; news covers the vendor breach	[20] [24]	Reported
17 to 22 Feb 2026	One source IP scans for SmarterMail on F5's sensors, then attempts CVE-2026-24423	[21]	Demonstrated
25 to 26 Feb 2026	KEV ransomware flag for CVE-2026-23760 goes to Known	[10]	Confirmed
21 Apr 2026	KEV ransomware flag for CVE-2025-52691 goes to Known	[10]	Confirmed

Discrepancies in the record

- **The fixed build.** The CVE and NVD records and CODE WHITE put the fix in Build 9511, which the release notes date to 15 January [4] [6] [13] [17]. The vendor's breach post says Build 9518 "contains all fixes related to the CVEs that were announced" and dates 9518 to 15 January, while the release notes date 9518 to 22 January [13] [14] (**Confirmed**). This study follows the release notes and NVD (**Inferred**).
- **The KEV date for CVE-2026-24423.** F5 Labs gives 2 February [21]; the catalog gives 5 February [9] [12] (**Confirmed**).

Part 2: the technical record

The mechanisms, at advisory level. For CVE-2026-23760 the CNA says the force-reset-password endpoint accepts anonymous requests and, for system administrator accounts, checks neither the old password nor a reset token [4] (**Confirmed**). For CVE-2026-24423 an unauthenticated caller can point the server at an attacker-controlled HTTP server whose response leads to command execution [6] (**Confirmed**). For CVE-2025-52691 CSA describes file upload to any location [1] (**Confirmed**). Later builds hardened reset tokens and removed the command-line action from routing rules (30 January), changed command-line use (13 February) and rebuilt the reset flow (5 November) [13] (**Confirmed**); reading them as a response to the January flaws is this study's inference (**Inferred**).

Why an admin password is a shell. The CVE-2026-23760 record notes that system administrator rights allow operating system commands through built-in management functions [4], which NVD notes amounts to SYSTEM or root on the host [5] (**Confirmed**). Huntress saw the System Events feature used this way, exploitation across multiple customers and a separate campaign against CVE-2025-52691 [18] (**Demonstrated** and **Reported**); ReliaQuest saw a volume-mount admin feature used to run commands [20] (**Reported**). An authentication bypass here is remote code execution in two steps (**Inferred**).

Public exploit material. watchTowr's public repository for CVE-2025-52691 is tagged by NVD as an exploit reference [2] [16] (**Demonstrated**), and Flare reports PoC material in Telegram channels [25] (**Reported**). watchTowr's title, "Attackers with decompilers strike again", points to patch diffing; reading the two-day gap between the 9511 fix and the first reported attack that way is this study's inference [15] (**Inferred**). CODE WHITE lists a further flaw, CVE-2026-40514, a partial authentication bypass fixed below Build 9610 (25 March 2026), not in KEV as of 10 November [9] [17] (**Confirmed**).

Part 3: who and why

CSA credits Chua Meng Han of CSIT with CVE-2025-52691 [3]; the CVE records credit watchTowr and CODE WHITE with both 2026 flaws, and VulnCheck adds its own researcher for CVE-2026-24423 [4] [8] (**Confirmed**). The record names actors in only two places, and neither is a government attribution.

- **The vendor says "Warlock Group"** for its own breach and says it has seen similar activity on customer machines [14] (**Confirmed** as the vendor's statement; the attribution is the vendor's).
- **ReliaQuest says Storm-2603**, with moderate-to-high confidence, because the installer and command-and-control tooling matched confirmed Warlock attacks; probes for CVE-2026-24423 hit the same server from different infrastructure it cannot attribute [20] (**Reported**). News recalls that Halcyon linked Warlock to Storm-2603 in October 2025 [24] (**Reported**; not opened).
- **Everyone else made no attribution.** Huntress saw 28 source IPs [18], and F5's single source sat in ASN 200593 in St. Petersburg [21] (**Demonstrated**). Flare saw Telegram channels trading PoC material and admin credentials [25] (**Reported**).

Storm-2603 deployed Warlock through SharePoint ToolShell in 2025 [27] (**Confirmed** in the library). The vendor says the attackers aimed to take Active Directory, create users and run encryptors [14] (**Confirmed** as the vendor's statement): ransomware, as KEV's flags agree [9] (**Confirmed**).

Part 4: impact and response

Victims. The only named victim is SmarterTools. About 12 Windows servers across its office network and a second data center appeared to be compromised, linked through Active Directory; segmentation kept the website, cart and account portal online [14] (**Confirmed** as the vendor's statement). ReliaQuest's victim is unnamed and was caught at staging [20] (**Reported**). No victim count, sector or regulator filing appears in any source opened (**Inferred**; regulator filings not checked).

Exposure. The counts differ by method. Shadowserver found about 6,000 likely vulnerable IPs by version check on 26 January [19] (**Demonstrated**). A Macnica researcher counted more than 8,550 vulnerable instances [22], F5 about 30,000 SmarterMail instances on Shodan [21], and Flare 1,185 of 17,754 servers showing bypass or RCE exposure [25] (**Reported**).

The vendor. SmarterTools shipped Build 9511 two days after acknowledging watchTowr's report, then hardening builds through 5 November, without naming a CVE or saying a flaw was exploited [13] [15] (**Confirmed**). Its breach post named its own unpatched VM as the way in and gave customers a hunting list [14] (**Confirmed**); this study reads that as unusually candid (**Inferred**).

Governments. CSA Singapore issued its alert on 29 December 2025, the same day the CVE was published [1] [3] (**Confirmed**). CISA's KEV required action is to apply vendor mitigations, follow BOD 22-01 guidance for cloud services, or stop using the product if mitigations are unavailable [9] [11] [12] (**Confirmed**). The Intelligence Hub indexes the KEV rows and the F5 Labs article [26] (**Confirmed**).

Part 5: the defender and vulnerability-management view

A self-hosted mail server is an edge device whose admin console can run commands as SYSTEM, and at the vendor it sat inside Active Directory (**Inferred** from [5] [14]).

Control	Where it meets the record
Check the installed build number, not the release note wording	"Critical security fixes." hid three KEV flaws [13]
Count the KEV clock from the fix, not the CVE	Fix 15 Jan, attack reported 17 Jan, CVE 22 Jan, KEV 26 Jan [4] [9] [13] [15]
Hunt after patching	Planted files waited 6 to 7 days; some customers were hit even after updating because access predated it [14]
Watch the KEV ransomware flag over time	Flags changed the same day, about 30 days and 85 days after addition [10]

What is overstated and what is understated

- **Overstated:** "nation-state ransomware". Storm-2603 is ReliaQuest's call and Warlock is the vendor's [14] [20]; no government has attributed this activity in any source opened (**Inferred**). So is "ransomware deployed": in both detailed accounts encryption was stopped or never started [14] [20] (**Reported** and **Confirmed**). The 30,000 Shodan figure counts instances, not vulnerable ones [21] (**Reported**).
- **Understated:** the release notes never say exploited [13], yet KEV marks all three flaws as ransomware-linked [9] (**Confirmed**). Compromise after updating [14] means patch counts overstate safety

(**Inferred**). No victim count exists in the record, so the real number of breached mail servers is unknown; the absence of a count is not evidence that it is small (**Inferred**).

MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0 Enterprise, CWE, CAPEC and D3FEND, with names and tactics from the library's `data/attack/` and `data/weaknesses/` files [27] (**Confirmed**). No source names ATT&CK technique ids; each row is this study's mapping (**Inferred**). None of the bound ids is revoked [27] (**Confirmed**). No source describes an industrial effect, so no ATT&CK for ICS table applies.

Groups, software and campaigns

Storm-2603, Warlock, Velociraptor, SimpleHelp, JWRapper and WinRAR have no group or software object in the library's ATT&CK data, so none is linked [27] (**Confirmed**).

Object	ATT&CK id	Relationship to this record
SharePoint ToolShell Exploitation	C0058	Lineage only: its description names Storm-2603, the actor ReliaQuest ties to one SmarterMail intrusion (9 Feb 2026) [20] [27]; not bound to SmarterMail exploitation

ATT&CK Enterprise techniques

ID	Name	Tactic(s)	Dated event or report	Sources
T1595.002	Vulnerability Scanning	Reconnaissance	CVE-2026-24423 probes on ReliaQuest's victim (9 Feb); one IP's reconnaissance on F5 sensors (17 Feb)	[20] [21]
T1587.004	Exploits (Develop Capabilities)	Resource Development	Attack two days after the 9511 fix, consistent with patch diffing (study inference) (17 Jan; published 22 Jan)	[15]
T1588.005	Exploits (Obtain Capabilities)	Resource Development	PoC material traded in Telegram channels (Flare, 18 Feb)	[25]
T1608.001	Upload Malware	Resource Development	Payload hosted on a legitimate cloud platform, earlier on GitHub (ReliaQuest, 9 Feb)	[20]
T1190	Exploit Public-Facing Application	Initial Access	Forum post (17 Jan); CISA records (22 Jan, 5 Feb); Huntress (22 Jan); KEV (26 Jan, 5 Feb); vendor (29 Jan); ReliaQuest (9 Feb); F5 (20 to 22 Feb)	[5] [7] [9] [14] [15] [18] [20] [21]
T1059	Command and Scripting Interpreter	Execution	OS command execution in both 2026 CVE records (22 and 23 Jan); System Events reconnaissance (Huntress, 22 Jan); volume-mount feature (ReliaQuest, 9 Feb)	[4] [6] [18] [20]
T1098	Account Manipulation	Persistence, Privilege Escalation	Forced reset of the system administrator password (CVE record, 22 Jan); tip that admin passwords were being reset (21 Jan)	[4] [15] [18]
T1136	Create Account	Persistence	Attackers aim to take Active Directory and create users (vendor post, 3 Feb)	[14]
T1218.007	Msiexec	Stealth	Legitimate Windows installer pulls the payload (ReliaQuest, 9 Feb)	[20]
T1070	Indicator Removal	Stealth	The attacker removes the System Event and test domain it created (Huntress, 22 Jan)	[18]
T1105	Ingress Tool Transfer	Command and Control	Payload downloaded from Supabase, earlier GitHub (ReliaQuest, 9 Feb)	[20]
T1219	Remote Access Tools	Command and Control	Velociraptor configured for C2 (ReliaQuest, 9 Feb); Velociraptor, SimpleHelp and JWRapper named by the vendor as tools in its breach (3 Feb)	[14] [20]
T1486	Data Encrypted for Impact	Impact	Encryption attempted and stopped at the vendor (29 Jan; post 3 Feb); KEV ransomware use Known for all three (5 Feb, 26 Feb, 21 Apr)	[9] [10] [14]

Fit notes (**Inferred**): the forced reset is bound as T1098 rather than Valid Accounts (T1078); Flare's credential dumps [25] show theft, not use. T1059 stays at the parent because no source names the interpreter. T1587.004 and T1608.001 are inexact: the patch-diffing reading is this study's inference, and ReliaQuest does not say who uploaded the payload. T1486 covers attempted encryption; none was completed. The vendor's hunting list names things to look for, not observed behavior, so T1059.001, T1505.003 and T1053.005 are not bound.

CWE and CAPEC

CWE	Name	Where it is assigned	Sources
CWE-434	Unrestricted Upload of File with Dangerous Type	CVE-2025-52691 (CISA ADP in NVD; KEV)	[2] [9] [27]
CWE-288	Authentication Bypass Using an Alternate Path or Channel	CVE-2026-23760 (CNA, KEV)	[4] [9] [27]
CWE-306	Missing Authentication for Critical Functionality (KEV wording: Missing Authentication for Critical Function)	CVE-2026-24423 (CNA, NVD, KEV)	[6] [7] [9] [27]

No record lists a CAPEC entry for these CVEs [2] [4] [6] (**Confirmed**). The library relates CWE-434 to CAPEC-1, CWE-288 to CAPEC-127 and CAPEC-665, and CWE-306 to CAPEC-12, CAPEC-36, CAPEC-62, CAPEC-166 and CAPEC-216 [27] (**Confirmed**). None describes these mechanisms, so none is bound; the nearest patterns, CAPEC-115 and CAPEC-650, relate to other weaknesses and are not bound either (**Inferred**). See the CWE Reference and CAPEC Reference.

D3FEND countermeasures

D3FEND countermeasure	Techniques the library maps it to (from this study)	Where it meets the record
Inbound Traffic Filtering	T1190	Mail servers in a DMZ away from domain controllers [20]
Network Traffic Filtering	T1190, T1105, T1219	Mail servers in a DMZ away from domain controllers [20]
Outbound Traffic Filtering	T1105, T1219	Allow only mail protocols outbound [20]; egress filtering would have blocked F5's attacker [21]
User Account Permissions, Account Locking, Restore User Account Access	T1098, T1136	Attackers aim to create users [14]; admin accounts taken over by reset [4]
Executable Allowlisting, File Integrity Monitoring	T1059 (both), T1486 (File Integrity Monitoring)	Random-named .ps1 and .aspx files in the hunting list [14]
Restore File	T1059, T1486	Systems restored from backups after the vendor breach [24]

The deciding control, updating to a fixed build, is Software Update, which the library does not relate to any technique bound here [27] (**Confirmed**). See the D3FEND Reference.

Navigator layer

The study's techniques are saved as an ATT&CK Navigator layer, `navigator/library-layers/smartertools-smartermail-2026.json` (open in Navigator). Scores: 75 for behavior in the CVE, KEV or CISA record, 50 for a vendor, research or news report, 25 for an inexact fit. T1486 scores 50: the encryption evidence is the vendor's statement, and KEV's flag records ransomware use, not observed encryption. Each comment names its source numbers.

Cross-cutting themes

- **Self-hosted mail is still a front door.** As in Exchange Marauder 2021: a pre-authentication flaw, automated exploitation within days, and admins who learn of it from researchers rather than the vendor (**Inferred**).
- **Patched is not clean.** In SharePoint ToolShell 2025 stolen machine keys outlived the patch; here planted files did the same [14] (**Inferred** comparison).
- **The same crew, a new door.** Storm-2603 and Warlock appear in both ToolShell and this record [20] [27], as in the extortion pattern of Cl0p File Transfer 2023; see Threat Actors: China (**Inferred**).

Sources

All sources were opened on 11 November 2026.

#	Source	URL	Opened	Grade
1	CVE Program record CVE-2025-52691 (CNA CSA), CVE Services API	cveawg.mitre.org/api/cve/CVE-2025-52691	2026-11-11	Confirmed
2	NVD, CVE-2025-52691 (page and API)	nvd.nist.gov/vuln/detail/CVE-2025-52691	2026-11-11	Confirmed
3	Cyber Security Agency of Singapore, AL-2025-124, Vulnerability in SmarterTools Software, 29 Dec 2025	csa.gov.sg/alerts-and-advisories/alerts/al-2025-124/	2026-11-11	Confirmed
4	CVE Program record CVE-2026-23760 (CNA VulnCheck, with the CISA ADP container), CVE Services API	cveawg.mitre.org/api/cve/CVE-2026-23760	2026-11-11	Confirmed
5	NVD, CVE-2026-23760 (page and API)	nvd.nist.gov/vuln/detail/CVE-2026-23760	2026-11-11	Confirmed
6	CVE Program record CVE-2026-24423 (CNA VulnCheck), CVE Services API	cveawg.mitre.org/api/cve/CVE-2026-24423	2026-11-11	Confirmed
7	NVD, CVE-2026-24423 (page and API)	nvd.nist.gov/vuln/detail/CVE-2026-24423	2026-11-11	Confirmed
8	VulnCheck, SmarterTools SmarterMail unauthenticated RCE via ConnectToHub API, 23 Jan 2026	vulncheck.com/advisories/smartertools-smartermail-unauthenticated-rce-via-connecttohub-api	2026-11-11	Confirmed
9	CISA, Known Exploited Vulnerabilities catalog JSON, version 2026.11.10	cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	2026-11-11	Confirmed
10	CISA, kev-data repository, commit history of known_exploited_vulnerabilities.json	github.com/cisagov/kev-data/commits/main/known_exploited_vulnerabilities.json	2026-11-11	Confirmed
11	CISA, CISA Adds Five Known Exploited Vulnerabilities to Catalog, 26 Jan 2026	cisa.gov/news-events/alerts/2026/01/26/...	2026-11-11	Confirmed
12	CISA, CISA Adds Two Known Exploited Vulnerabilities to Catalog, 5 Feb 2026	cisa.gov/news-events/alerts/2026/02/05/...	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
13	SmarterTools, SmarterMail release notes (Builds 9406 to 9805)	smartertools.com/smartermail/release-notes/current	2026-11-11	Confirmed
14	SmarterTools community, Summary of SmarterTools Breach and SmarterMail CVEs, by the company's CCO, 3 Feb 2026	portal.smartertools.com/community/a97747/...	2026-11-11	Confirmed (vendor statement)
15	watchTowr Labs, SmarterTools SmarterMail WT-2026-0001 auth bypass, 22 Jan 2026	labs.watchtowr.com/attackers-with-decompilers-strike-again-...	2026-11-11	Confirmed (own disclosure); Reported (forum post and tip)
16	watchTowr, public repository for CVE-2025-52691 (named, not linked, because NVD tags it as an exploit)	github.com/watchtowrlabs/watchTowr-vs-SmarterMail-CVE-2025-52691	2026-11-11	Demonstrated
17	CODE WHITE, public vulnerability list	code-white.com/public-vulnerability-list/	2026-11-11	Confirmed
18	Huntress, SmarterMail account takeover leading to RCE, 22 Jan 2026	huntress.com/blog/smartermail-account-takeover-leading-to-rce	2026-11-11	Demonstrated (own telemetry); Reported
19	Shadowserver Foundation, post on CVE-2026-23760 scanning, 26 Jan 2026 (read through the public Bluesky API)	bsky.app/profile/shadowserver.bsky.social/post/3mddfwextds26	2026-11-11	Confirmed
20	ReliaQuest, Threat Spotlight: Storm-2603 exploits CVE-2026-23760 to stage Warlock ransomware, 9 Feb 2026	reliaquest.com/blog/threat-spotlight-storm-2603-...	2026-11-11	Reported
21	F5 Labs, Looking at the SmarterMail API vulnerability CVE-2026-24423, 12 Mar 2026	f5.com/labs/articles/looking-at-the-smartermail-api-vulnerability-cve-2026-24423	2026-11-11	Demonstrated (sensor data); Reported
22	BleepingComputer, Over 6,000 SmarterMail servers exposed to automated hijacking attacks, 27 Jan 2026 (citing Shadowserver and a Macnica researcher)	bleepingcomputer.com/news/security/over-6-000-smartermail-servers-...	2026-11-11	Reported
23	BleepingComputer, CISA warns of SmarterMail RCE flaw used in ransomware attacks, 6 Feb 2026	bleepingcomputer.com/news/security/cisa-warns-of-smartermail-rce-...	2026-11-11	Reported
24	BleepingComputer, Hackers breach SmarterTools network using flaw in its own software, 9 Feb 2026	bleepingcomputer.com/news/security/hackers-breach-smartertools-network-...	2026-11-11	Reported
25	BleepingComputer, sponsored content written by Flare, Telegram channels expose rapid weaponization of SmarterMail flaws, 18 Feb 2026	bleepingcomputer.com/news/security/telegram-channels-expose-...	2026-11-11	Reported
26	Team Star Wolf Intelligence Hub, feed.json and the v7 monthly shards (KEV rows of 26 Jan and 5 Feb, F5 Labs row of 12 Mar)	teamstarwolf.github.io/intelligence-hub/data/feed.json	2026-11-11	Confirmed
27	TeamStarWolf library: `case-studies/SHAREPOINT_TOOLSHELL_2025.md`, `case-studies/THREAT_ACTORS_CHINA.md`, `mitre/campaigns/C0058.md`, and `data/attack/` (ATT&CK v20.0) and `data/weaknesses/` files	github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack	2026-11-11	Confirmed

Not opened, so not cited as sources: watchTowr's blog post on CVE-2025-52691, Halcyon's October 2025 report linking Warlock to Storm-2603, Microsoft's Storm-2603 profile, Cisco Talos's Warlock and Velociraptor analysis, and the SmarterMail forum post that watchTowr cites.

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- SharePoint ToolShell 2025, Exchange Marauder 2021, Cl0p File Transfer 2023, Threat Actors: China, Ransomware Ecosystem, The Year 2026 in Intrusions, Timeline
- Other 2026 exploitation studies: The BeyondTrust Remote Support and PRA command injection, The cPanel and WHM authentication bypass, The Check Point Remote Access VPN IKEv1 authentication bypass
- Threat Actors, Malware Families, Notable Incidents
- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Email Security Reference, Edge Device Security Reference, Ransomware Defense Reference, Incident Response Reference, Threat Hunting Reference, Vulnerability Management Reference, Vulnerability Prioritization Reference
- Campaigns: C0058 SharePoint ToolShell Exploitation (lineage, not bound)
- Techniques: T1190 Exploit Public-Facing Application, T1595.002 Vulnerability Scanning, T1587.004 Exploits, T1588.005 Exploits, T1608.001 Upload Malware, T1059 Command and Scripting Interpreter, T1098 Account Manipulation, T1136 Create Account, T1218.007 Msiexec, T1070 Indicator Removal, T1105 Ingress Tool Transfer, T1219 Remote Access Tools, T1486 Data Encrypted for Impact
- CAPEC: CAPEC-115 and CAPEC-650 (nearest patterns, not bound)
- Navigator layers, including this study's layer, smartertools-smartermail-2026.json
- The Team Star Wolf Intelligence Hub
- All case studies